Segurança da Informação– GBC083

Prof. Rodrigo Sanches Miani – FACOM/UFU

Tópicos da aula

Auditoria e Segurança da Informação (GSI035)

Tópicos

1. Motivação para o estudo de segurança
2. Pilares da segurança
3. Ataques
4. Mecanismos de defesa



Motivação

Auditoria e Segurança da Informação (GSI035)

Motivação – importância da segurança

- Importância dos computadores e das redes de computadores na vida das pessoas está cada vez maior;
- Para algumas empresas, os serviços prestados pelas redes se tornaram tão fundamentais quanto a energia elétrica e o serviço de telefone;
- As redes têm sido utilizadas para acessar dados sensíveis e para realizar transações também sensíveis;
  - Exemplos?



Motivação – importância da segurança

- A **importância** das redes e o caráter **sensível** de dados e transações chamam atenção de indivíduos e grupos mal intencionados:
  - Muitos destes grupos estão buscando formas de obter vantagens financeiras;
  - Alguns destes grupos buscam notoriedade.



Motivação – importância da segurança

- Problemas de segurança podem:
  - Causar perdas financeiras;
  - Sujar a reputação da empresa;
  - Causar problemas com a justiça;
  - O que mais?



Motivação – importância da segurança

- Problemas de segurança podem:
  - Causar perdas financeiras;
  - Sujar a reputação da empresa;
  - Causar problemas com a justiça;
  - O que mais?
  - Matar!
    - https://www.kaspersky.com.br/blog/stuxnet-as-origens/4391/
    - https://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/



Motivação – importância da segurança

- É comum ler nos noticiários relatos de ataques provocados por grupos de *cibercriminosos*:
  - Hackers invadiram e roubaram "armas" utilizadas pela NSA.
  - Roubos de senhas de usuários de grandes sistemas como o Dropbox.
  - Invasão e vazamento de dados da Sony Pictures.
  - Ataques derrubam servidores DNS e interrompem serviços como Twitter, Facebook e Google.



Motivação – importância da segurança

- Mais notícias:
  - Caso *Snowden*;
  - Vulnerabilidade *Heartbleed*;
  - Invasão de babás eletrônicas;
  - Invasão de sistemas fechados de monitoramento por câmera;
  - Sequestro de dados de empresas (*ransomware*);



Motivação – importância da segurança

- Algumas discussões importantes atuais:
  - Privacidade dos indivíduos (*Google*, *Facebook*, *Smart cities*, câmeras de vigilância, etc.);
  - Segurança em Internet das Coisas;
  - Segurança na Computação em Nuvem;
  - Segurança em ambiente BYOD (*Bring Your Own Device*);
  - Segurança em infraestruturas críticas (sistemas SCADA - *supervisory control and data acquisition*): *smart grids*, usinas nucleares, etc.



O que fazer?

Pergunta:

E aí? Como tratar os inúmeros problemas discutidos anteriormente?



O que fazer?

Pergunta:

E aí? Como tratar os inúmeros problemas discutidos anteriormente?

Uma **parte** da resposta envolve planejar e implementar MECANISMOS DE SEGURANÇA.



Implementando segurança - Desafios

- Computadores atuais são ricos em funcionalidades e complexos;
  - Aumento de funcionalidades -> aumento de problemas!
- Maioria dos usuários são leigos;
  - Atacantes tentam aproveitar essa brecha;
- Vontade de tornar tudo disponível o tempo todo e em qualquer lugar aumenta os problemas.



Implementando segurança - Desafios

- Mecanismos de segurança geram obstáculos também para as pessoas bem intencionadas;
  - Exemplos: biometria e segurança de bancos, empresas que proíbem a navegação em determinados sites e etc.
  - Encontrar balanço entre **segurança e inconveniência**;

- A segurança costuma ser implementada usando uma visão **reativa**;
  - Exemplo: 11/09



Pilares

Auditoria e Segurança da Informação (GSI035)

Pilares da segurança

- Um modelo de segurança simples mas largamente aplicado é conhecido como a tríade CID - Confidencialidade, Integridade e Disponibilidade;

- Os três conceitos acima envolvem os **objetivos fundamentais** da segurança tanto para dados quanto para serviços de informação e computação;

- Veremos que a violação de qualquer um dos três princípios implica em sérias consequências para os envolvidos.



https://www.informationsecuritybuzz.com/isbuzz-expert-panel/cia-triad-and-new-emerging-technologies-big-data-and-iot/

Pilares da segurança

Confidencialidade:

- Garante que as informações não serão acessadas por agentes não autorizados.



Objetivos da segurança

Integridade:

- Garante que sistemas e informações só sejam modificados dentro das condições previstas;



Objetivos da segurança

Disponibilidade:

- Garante que os dados e sistemas estejam disponíveis para aqueles que tem o direito de utilizá-los;



Ataques

Auditoria e Segurança da Informação (GSI035)

Ataques - Definição

- Qualquer ação que comprometa algum dos três princípios mostrados anteriormente:
  - Confidencialidade, integridade e disponibilidade



Ataques – Tipos

- Ataques passivos
  - Obter informações a partir do monitoramento de comunicações;
  - Tipos: vazamento de conteúdo de mensagem e análise de tráfego.

- Ataques ativos
  - Envolvem alguma modificação do fluxo de dados ou a criação de fluxo falso;
  - Tipos: disfarce, repasse, modificação de mensagem e negação de serviço.



Ataques

- Força bruta: atacante testa exaustivamente diferentes possibilidades até encontrar um código ou senha;

- *Man-in-the-middle*: atacante se posiciona entre transmissor e receptor. Captura as mensagens, coleta as informações necessárias e repassa as mensagens para o receptor, de forma que ninguém perceba a presença do atacante;



Ataques

- Negação de serviço:
  - Atacante tenta esgotar recursos do servidor enviando grande volume de requisições;
  - Pode acarretar de perda de desempenho a indisponibilidade do serviço;
  - Variação: ataque distribuído de negação de serviço.



Ataques

- Malwares (malicious softwares):
  - Vírus:
  - Spywares;
  - Worms (vermes);
  - Cavalos de tróia;



Ataques

- Vírus:
  - infectam o computador e seguem tentando espalhar suas cópias para outros arquivos dentro do mesmo computador;
  - consegue infectar a máquina por meio da execução de um arquivo malicioso;

- Spywares: dedicado a recolher informações de comportamento do usuário de maneira não autorizada para enviar a entidades externas;



Ataques

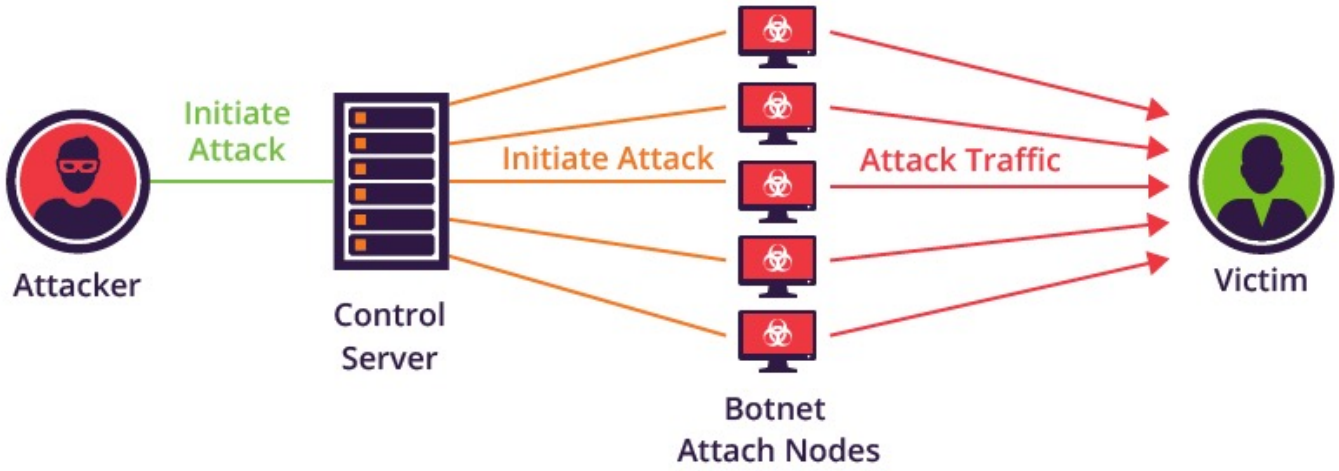
- Cavalo de tróia: programa que parece ter uma função útil, mas também tem uma função oculta e potencialmente maliciosa.

- *Worms*: variação ainda mais agressiva de um vírus, pois conseguem operar de forma autônoma se espalhando pelos computadores de uma rede. Podem sofrer mutações, alterando seu código para dificultar a detecção;



Ataques

- Botnet:
  - Rede formada por computadores dominados por um atacante;
  - Cada computador é denominado bot (robot) ou zumbi;
  - Com as botnets, atacantes formam exércitos para realizar ataques como: negação de serviço e envio de spam.



Extraída de: https://www.incapsula.com/blog/how-to-identify-a-mirai-style-ddos-attack.html



Ataques

- Spam:
  - Envio de mensagem não solicitada;
  - Correntes, propagandas, malwares, phishing, etc.

- Backdoors:
  - Pontos secretos de entrada em softwares;
  - Usados por programadores como atalhos para manutenção e testes de sistemas;
  - Usados por atacantes como atalhos para acessos não autorizados;

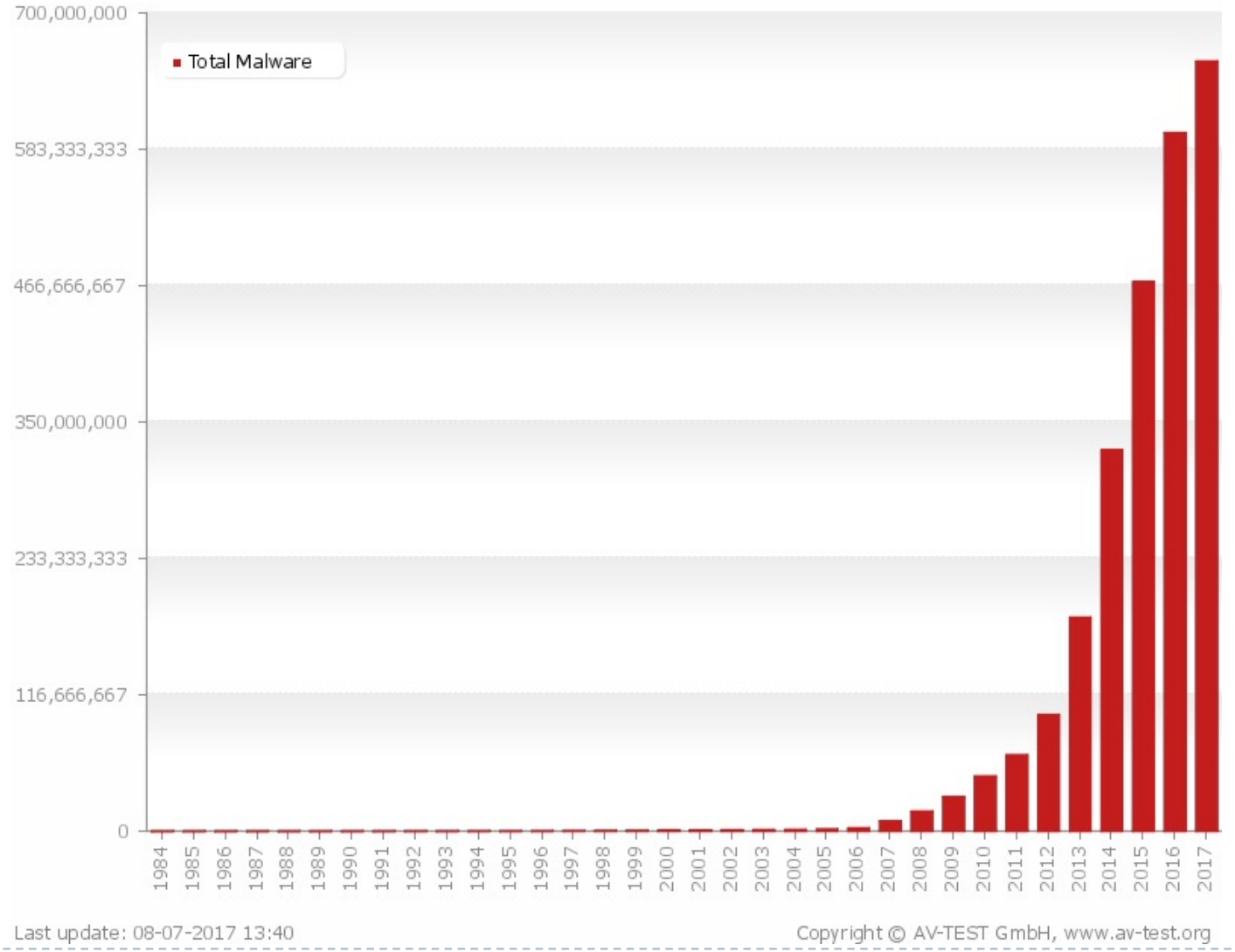


Ataques

- Engenharia Social:
  - Técnica que explora as fraquezas humanas e sociais;
  - Tem como objetivo enganar e ludibriar pessoas, a fim de conseguir informações;
  - Ataque clássico consiste em se fazer passar por um alto funcionário que tem problemas urgentes de acesso ao sistema;
  - Ataque muito difícil de prevenir ou detectar;
  - Kevin Mitnick, famoso *hacker*, afirmou que utilizava técnicas de Engenharia Social em mais de 80% de seus ataques.



Exemplos de ataques à redes – Malware (AV-Test)



Mecanismos de defesa

Auditoria e Segurança da Informação (GSI035)

Defesas

- Protocolos de segurança:
  - SSL (Secure Socket Layer):
    - Segurança na camada de transporte;
    - Oferece canal seguro para camada de aplicação;
    - Navegadores e servidores HTTP implementam o SSL;
    - Muito utilizado em transações na Web que envolvem, por exemplo, pagamento com cartão de crédito;
    - SSL implementa os mais famosos e importantes algoritmos de criptografia como RSA e AES.



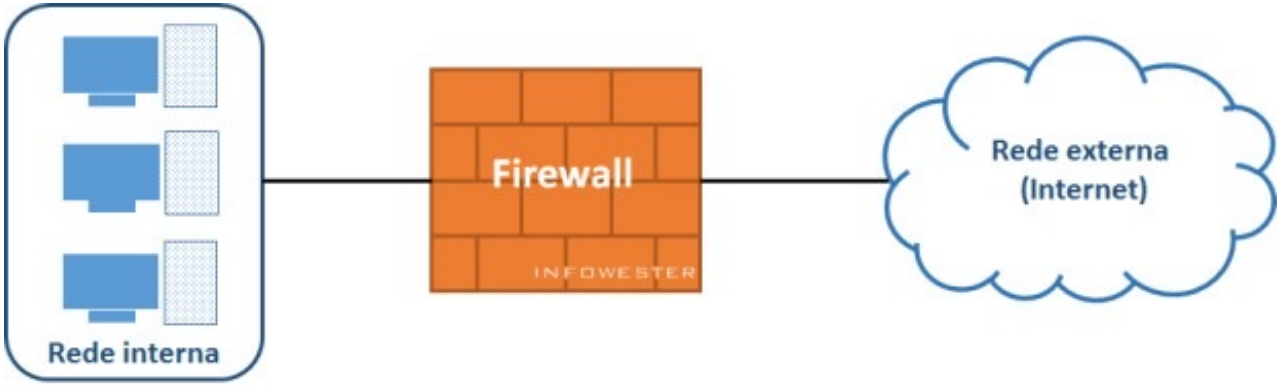
Defesas

- Protocolos de segurança:
  - IPSEC:
    - Autenticação e cifragem de pacotes IP (mecanismo de segurança na camada de rede);
    - Construção de Virtual Private Networks (VPNs)
    - Authentication Header (AH): autenticação e integridade;
    - ESP (Encapsulating Security Payload): autenticação, integridade e sigilo.



Defesas

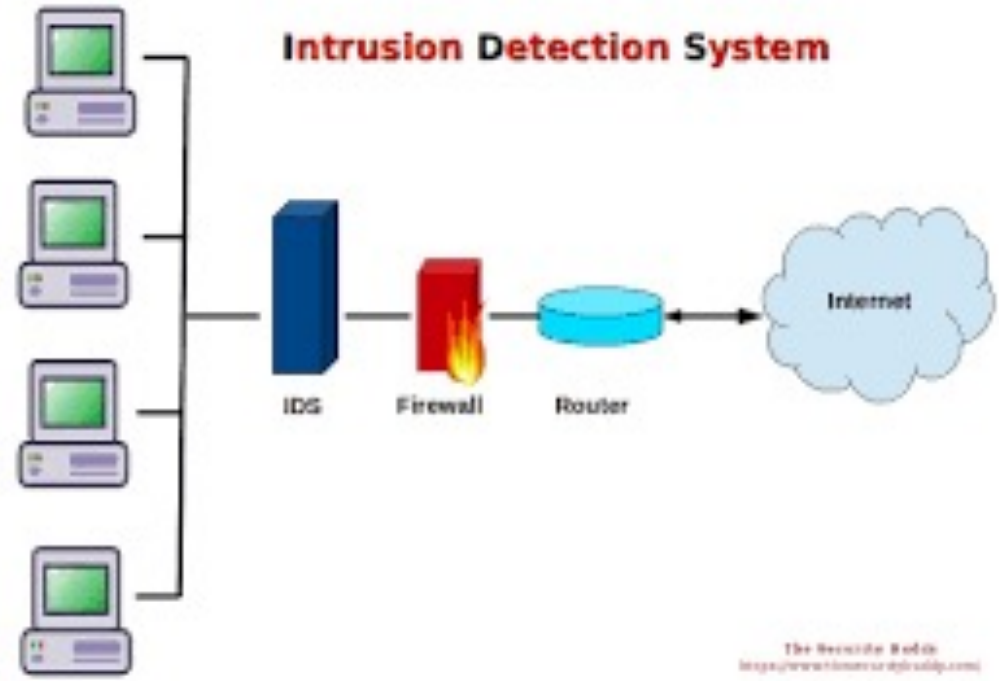
- Firewall:
  - Delimitam o perímetro de defesa da rede;
  - Ponto por onde todo o tráfego que entra e sai da rede deve passar;
  - Analisa todo o tráfego e bloqueia pacotes que não atendam a regras;
  - Possibilita, por exemplo, bloquear acesso externo a sistemas que só devem ser acessados por agentes internos da rede.



http://helpdigitalti.com.br/blog/o-que-e-firewall-conceito-tipos-e-arquiteturas

Defesas

- Sistemas de detecção de intrusão (Intrusion Detection System – IDS):
  - Detecção de situações nas quais há acesso (ou tentativa) não autorizado aos sistemas;
  - Baseados em assinaturas;
  - Baseados no comportamento normal;
  - Problema: alarmes falsos
  - Exemplo: Snort.



Defesas

- Antivírus:
  - Detecção, identificação e remoção de vírus;
  - Várias soluções disponíveis no mercado:
    - AVG;
    - Avast;
    - Mcafee;
    - Norton;
    - Symantech;
    - Panda.



Defesas

- Políticas de segurança:
  - Diz respeito às regras que devem ser elaboradas e seguidas pelos utilizadores dos recursos de informação de uma empresa. Exemplos:
    a) Backups – frequência? Quais dados? Onde armazenar...;
    b) Segurança no acesso físico – Quem pode entrar? Quando?;
    c) Conscientização de usuários quanto a comportamento adequado que evita problemas;
    d) Atualizações constantes de antivírus, bases de assinaturas, etc;
    e) Estudo de incidentes ocorridos;
    f) Análise de métricas de segurança.



Criptografia

- A criptografia permite:
  - Que o emissor da informação use uma chave para embaralhar a informação de maneira que só o destinatário com a mesma chave a entenderá;
  - Que o emissor da informação seja autenticado;
  - Que a informação não seja alterada durante o seu percurso (que o destino consiga verificar se houve alguma alteração).



Organizações totalmente seguras?

Com base no que foi discutido, é possível afirmar que uma organização é 100% segura?



Organizações totalmente seguras?

Com base no que foi discutido, é possível afirmar que uma organização é 100% segura?

- Não! Não existe um modelo de segurança à prova de ataques;
- Um sistema que está seguro hoje pode não estar seguro amanhã;



Organizações totalmente seguras?

Apesar de toda a parafernalia tecnológica existente para a proteção das redes de computadores vimos que não existe organização ou sistema 100% seguro. Neste contexto, qual seria o "elo mais fraco" da segurança de redes?



Organizações totalmente seguras? - Exemplo

- A segurança envolve:
  - Aspectos tecnológicos – um sistema de autenticação robusto;
  - Aspectos técnicos – um administrador de segurança experiente e com vastos conhecimentos na área;
  - Aspectos sociais/humanos – funcionários que seguem políticas e boas práticas;
  - Aspectos educacionais – fornecer treinamento aos envolvidos – funcionários e terceiros.



Organizações totalmente seguras? – O que fazer?

1. Definir os recursos que devem ser protegidos;
2. Especificar quem irá administrar a segurança;
3. Determinar o valor que será utilizado como investimento;
4. Criar uma **política** que descreve a forma de proteção dos recursos e os controles de acesso ao sistema, transações e comunicações;
5. Usar a abordagem conhecida como segurança em camadas.



Organizações totalmente seguras? – Conclusão

- O objetivo não é construir uma rede 100% segura, mas sim um sistema confiável:
  - Capaz de anular os ataques mais casuais;
  - Tolerar acidentes! Ter um plano de contingência (famoso plano B).



Roteiro de Estudos

1. Leitura do Capítulo 1 (Introdução) – "Criptografia e segurança de redes. Princípios e práticas". William Stallings;
2. Estudo da vídeo-aula referente ao Tópico 1;
3. Resolução do TP1.



Roteiro de Estudos

Material complementar:

- Vídeo aula 1 do curso de Segurança da Informação da UNIVESP
  - https://www.youtube.com/watch?v=JrVS7YsGw8w&list=PLxI8Can9yAHenoHipBXp9XuJY4BBxBUPQ&index=2

- TED Talks:

1. https://www.youtube.com/watch?v=erCAp_Bd0AQ
2. https://www.youtube.com/watch?v=66-mr600NjU

